

Trace Requirements

Product scope, testable requirements, and storage design

1. Customer Statement of Requirements

Trace helps an individual builder review an application before release. The web application connects a GitHub repository. The desktop application, built with Tauri and React, lets the builder select a local project directory. Trace assigns each agent one review category and returns findings that point to affected code and explain the risk in plain language. Trace supports Security, Engineering, Product, Legal, and Accessibility reviews. Trace requires approval before it changes a local file. A builder can require approval for GitHub pull requests or enable automatic pull-request creation in project settings.

Trace serves one person per account. Team workspaces, GitLab imports, ZIP uploads, and automatic local-file changes sit outside the first release.

2. Requirements Specification

2.1 User Roles

- Builder: A signed-in individual who owns projects, configures agents, starts reviews, and approves remediation.

2.2 Review Categories

- Security: Authentication, authorization, secrets, insecure dependencies, input handling, and common application vulnerabilities.
- Engineering: Build and deployment configuration, error handling, observability, performance, testing gaps, and maintainability risks.
- Product: Missing user flows, confusing states, incomplete onboarding, and launch risks that affect a builder's customers.
- Legal: Privacy practices, data collection, consent, terms, licenses, and other legal risks. Privacy findings belong to this category.
- Accessibility: Barriers that prevent people with disabilities from using the application.

2.3 Functional Requirements

Account and access

- FR-01 Account registration: WHEN a visitor selects GitHub, Google, or email/password sign-in THEN Trace SHALL create or sign in to a builder account.
- FR-02 Account isolation: WHEN a builder requests a project, agent, review, finding, or remediation artifact THEN Trace SHALL return only records owned by that builder.
- FR-03 Credential management: WHEN a builder connects GitHub or saves a bring-your-own-key provider credential THEN Trace SHALL encrypt the credential before storage and show only a masked value after saving it.

Project intake and classification

- FR-04 GitHub import: WHEN a builder authorizes GitHub in the web application and selects a repository and branch THEN Trace SHALL create a project linked to that repository and branch.
- FR-05 Desktop project selection: WHEN a builder selects a local project directory in the Trace desktop application THEN Trace SHALL create a project linked to that directory and retain the local path only on the builder's device.
- FR-06 Input validation: WHEN a builder submits a malformed repository selection, a directory that Trace cannot read, or a directory outside the builder's selected project THEN Trace SHALL reject the input and explain how to correct it.
- FR-07 Project category: WHEN a builder creates or edits a project THEN Trace SHALL require one predefined project category, including Entertainment, Educational, Sports, Gaming, Business, Health, Finance, Social, Productivity, E-commerce, and Other.
- FR-08 Project management: WHEN a builder opens the project list THEN Trace SHALL show each project name, input source, category, latest review status, and last review date.

Agent configuration

- FR-09 Agent catalog: WHEN a builder opens the agent workspace THEN Trace SHALL list system agents and builder-created agents with their assigned review category, status, provider, selected model, skills, and fallback order.
- FR-10 Custom agents: WHEN a builder supplies a unique agent name, personality, one review category, model provider, model, and skills THEN Trace SHALL create an agent owned by that builder. Trace SHALL allow only one assigned review category per agent: Security, Engineering, Product, Legal, or Accessibility.
- FR-11 Provider access: WHEN a builder configures an agent THEN Trace SHALL offer Trace-managed model access by default and let the builder select a supported bring-your-own-key provider credential.
- FR-12 Fallback providers: WHEN a selected provider returns an availability, rate-limit, or capacity failure THEN Trace SHALL retry the work with the next configured provider and record the provider used for the completed attempt.

Reviews and findings

- FR-13 Review selection: WHEN a builder starts a review THEN Trace SHALL require a project, source revision, and one or more review categories: Security, Engineering, Product, Legal, or Accessibility. Trace SHALL assign only agents whose review category matches a selected category.
- FR-14 Review lifecycle: WHEN Trace accepts a review request THEN Trace SHALL show queued, running, completed, failed, or cancelled status and the assigned agents with their review categories.
- FR-15 Findings: WHEN an agent identifies a risk THEN Trace SHALL store and display a title, review category, severity, explanation, affected file or source location when available, evidence, recommendation, reviewing agent, and review timestamp.
- FR-16 Finding triage: WHEN a builder views a completed review THEN Trace SHALL let the builder filter findings by review category, severity, status, and agent, and mark a finding as open, accepted, resolved, or dismissed with a reason.
- FR-17 Failure handling: WHEN a review fails after retries THEN Trace SHALL preserve partial findings, state the failed stage and provider error class, and let the builder retry the review.
- FR-18 Review history: WHEN a builder opens a project THEN Trace SHALL display its past reviews, their source revisions, their findings, and remediation status.

Proposed changes and remediation

- FR-19 Change proposal: WHEN an agent recommends a code change THEN Trace SHALL show the builder a human-readable explanation, affected files, and a proposed diff before it produces a remediation artifact.
- FR-20 GitHub remediation: WHEN a builder reviews and approves a proposal for a GitHub-linked project THEN Trace SHALL create a pull request containing the approved change and link the pull request to the finding. WHEN a builder enables automatic pull-request creation for a GitHub-linked project THEN Trace SHALL create a pull request for each proposed GitHub remediation and link it to the finding.
- FR-21 Desktop remediation: WHEN a builder reviews and approves a proposal for a project selected in the desktop application THEN Trace SHALL create a recoverable backup of each affected local file, apply the approved change to the selected local project directory, and link the change to the finding.
- FR-22 Approval guard: WHEN a builder has not approved a proposal and has not enabled automatic pull-request creation for the GitHub-linked project THEN Trace SHALL not modify a repository or create a pull request. Trace SHALL require approval before it changes a local file.
- FR-23 Remediation record: WHEN Trace creates a pull request or changes a local file THEN Trace SHALL record the approver, approval time, source revision, artifact location or local file path, and affected finding.

2.4 Non-Functional Requirements

- NFR-01 Availability: Trace SHALL maintain 99.9% monthly availability for account access, project browsing, and review submission, excluding announced maintenance.
- NFR-02 Dashboard performance: WHEN a builder opens a project list with up to 100 projects THEN Trace SHALL return the list within 2 seconds at the 95th percentile under normal operating load.
- NFR-03 Review start: WHEN Trace accepts a review request under normal operating load THEN Trace SHALL assign it to a queue within 60 seconds.
- NFR-04 Review resilience: WHEN a model provider fails with a retryable error THEN Trace SHALL retry through the configured fallback chain before marking the review failed.
- NFR-05 Data encryption: Trace SHALL encrypt MinIO source artifacts and secrets at rest and use TLS for data in transit.

- NFR-06 Secret protection: Trace SHALL redact detected secrets from application logs, agent prompts, findings, error messages, local-file changes, and pull requests unless the builder explicitly reveals an individual value in a protected view.
- NFR-07 Authorization: Trace SHALL enforce ownership checks for each project, agent, source artifact, review, finding, provider credential, local-file-change, and pull-request operation.
- NFR-08 Data deletion: WHEN a builder deletes a project THEN Trace SHALL remove its MinIO source artifacts and provider-sent source copies under Trace control within 30 days and retain only records required for security, accounting, or legal obligations. Trace SHALL leave source files in a desktop-selected directory under the builder's control.
- NFR-09 Auditability: Trace SHALL record account access, source imports, review starts, provider fallback events, approval decisions, automatic pull-request settings, local-file changes, and pull-request creation with timestamps.
- NFR-10 Accessibility: Trace SHALL meet WCAG 2.2 AA for core flows: sign-in, project import, review start, findings triage, and remediation approval.
- NFR-11 Browser support: Trace SHALL support the current and previous major versions of Chrome, Firefox, Safari, and Edge.
- NFR-12 Observability: Trace SHALL capture application errors, review failures, provider latency, fallback events, and queue delay with Sentry and LangSmith without storing raw secrets.
- NFR-13 Recovery: Trace SHALL back up PostgreSQL daily, retain backups for 30 days, and restore a production backup within 4 hours during a declared recovery event.
- NFR-14 Source integrity: Trace SHALL bind each review, finding, proposal, local-file change, and pull request to the repository commit SHA or local-project source hash used for the review.

2.5 Business Rules and Edge Cases

- Trace reads only the local project directory that a builder selects in the desktop application and asks for a new selection when the directory becomes unavailable.
- Trace warns the builder when a GitHub branch changes after the review begins and requires a new review before remediation.
- Trace preserves the last completed review when a later review fails.
- Trace gives a builder one selected project category. The builder can change it before a new review.
- Trace treats Legal findings as informational guidance and asks the builder to consult qualified counsel for legal decisions.
- Trace does not grant a model provider access to a project until the builder starts a review.

2.6 Out of Scope for the First Release

- GitLab imports and ZIP uploads.
- Multi-person workspaces, invitations, roles, and shared projects.
- Local-file changes without explicit review and approval.
- Automated deployment, production monitoring, and continuous scanning.

3. Data and Storage Blueprint

3.1 Data Input

Input	Mechanism	Data captured
GitHub repository	GitHub OAuth or GitHub App authorization in the web application; builder selects repository and branch	Repository identifier, branch, commit SHA, source snapshot needed for the review, pull-request permission
Local project directory	Builder selects a directory in the Tauri + React desktop application	Local path stored on the device, file manifest, source hash, and project metadata
Manual configuration	Builder uses forms to create projects and agents, select categories, connect providers, start reviews, triage findings, and approve changes	Account profile, project category, agent settings, provider preferences, review selections, finding status, approval records

3.2 Storage Design

Storage	Technology	Purpose
Primary database	PostgreSQL	Accounts, OAuth connections, projects, agents, provider settings, review runs, findings, approvals, remediation artifacts, audit events
Source and artifacts	MinIO, configured for encrypted S3-compatible object storage	GitHub source snapshots, review exports, evidence attachments, and remediation records
Cache and work queue	Redis	Review jobs, status updates, rate limits, idempotency keys, and short-lived cached views
Observability platforms	LangSmith and Sentry	Agent traces, provider performance, errors, and operational events with secrets redacted

3.3 Core Data Records

- Account: ID, sign-in method, encrypted OAuth connections, created date, and consent records.
- Project: ID, owner account ID, name, project category, source type, repository reference or device-local path reference, source hash, and current source revision.
- Agent: ID, owner account ID, name, personality, assigned review category, skills, provider, model, fallback order, and encrypted BYOK reference when selected.
- Review run: ID, project ID, source revision, selected review categories, assigned agents, lifecycle status, provider attempts, timestamps, and error class.
- Finding: ID, review run ID, category, severity, title, explanation, evidence, location, recommendation, triage status, and reviewer agent.
- Remediation: ID, finding ID, proposed diff, builder approval record, output type, local file path or pull-request URL, and source revision.

3.4 Data Retention and Access

Trace stores project data under the owning builder account. PostgreSQL keeps relational records. MinIO holds encrypted GitHub source snapshots and generated files. Redis keeps transient work state and does not serve as the source of record. The desktop application retains local paths on the builder's device and reads only the directory the builder selected. A builder can delete a project and its Trace-managed artifacts. Trace encrypts stored secrets and source artifacts, limits access by account ownership, and redacts secrets before logs or model prompts leave the platform.